

מודול 6 — תרגול ותרchiשים

חומר לימוד

1 יחידות

תוכן העניינים

1.  תרגול — מודול 6: סריקה ומיפוי

תרגול — מודול 6: סריקה ומיפוי

חלק א' — שאלות תרגול (עם תשובות). חלק ב' — תרחיש מהחיים האמיתיים.

חלק א' — שאלות תרגול

Q1. איזו פקודת nmap מבצעת גילוי מארחים בלבד (ללא סריקת פורטים)?

Q2. מה עושה `-sV`, ולמה הוא קריטי לחקר חולשות?

Q3. איזו פקודה סורקת את כל 65,535 הפורטים?

Q4. אילו כלים מְמַנִּים HTTP? ואילו מְמַנִּים SMB?

Q5. מהי חולשת MS17-010, ואיזה סקריפט nmap בודק אותה?

Q6. מה עושה `searchsploit`, ומהו CVE?

Q7. מהי הפקודה המומלצת ל-nmap "כל-באחד" בתחילת מנייה?

Q8. מדוע לא כדאי לסמוך רק על Nessus?

תשובות

1. `<רשת> -sn nmap .`

2. מזהה גרסאות שירותים; הגרסה קובעת אילו Exploits ידועים רלוונטיים.

3. `<ip> -p - nmap .`

4. HTTP: `nikto`, `gobuster`, `whatweb`; SMB: `enum4linux`, `smbclient`, `nmap smb-scripts`.

5. חולשת SMB קריטית (WannaCry); נבדקת ב- `smb-vuln-ms17-010` `--script` `-p445 nmap .`

6. `searchsploit` מחפש Exploits במאגר Exploit-DB המקומי; CVE = מזהה ייחודי לחולשה.

7. `<ip> scan.txt -oN -sV -sC nmap .`

8. סריקה אוטומטית רועשת ומפספסת חולשות לוגיות שרק מנייה ידנית מגלה.

חלק ב' — תרחיש מהחיים האמיתיים

🎯 “מנייה מלאה של Kioptrix”

התקן את **Kioptrix Level 1** (VulnHub) במעבדה מבודדת ובצע מנייה מלאה — בדיוק כמו בבדיקה אמיתית:

```
# 1. גילוי
nmap -sn 192.168.56.0/24

# 2. סריקה מלאה + שמירה
nmap -sC -sV -p- -oN kioptrix.txt <target-ip>

# 3. מנייה לפי שירות
nikto -h http://<target-ip>
gobuster dir -u http://<target-ip> -w /usr/share/wordlists/dirb/common.txt
enum4linux -a <target-ip>

# 4. חקר חולשות
searchsploit apache 1.3
searchsploit samba 2.2
```

המשימה: הרכב “דוח מנייה” עם טבלת פורטים (פורט/שירות/גרסה), ממצאי כל שירות, ולפחות **וקטור תקיפה אחד** מנומק (Exploit/CVE). זה יהיה הקלט למודול 7.

💡 פתרון מנחה

Kioptrix 1 יחשוף לרוב: `Apache 1.3.20 + mod_ssl 2.8.4` (“OpenFuck” CVE-2002-0082), `Samba 2.2.1a` (CVE-2003-0201, `trans2open`), `OpenSSH 2.9`. **וקטור מומלץ:** `Samba trans2open` (יציב ב-Metasploit) `root` → `mod_ssl` חלופה.

🎯 שמור את דוח המנייה — במודול 7 ננצל בפועל את החולשה שזיהית.

⬅ חזרה למודול · תרגילים מעשיים